Informe ejecutivo para la propiedad

Estado del sistema de protección de la información — julio de 2026

Código de documento	SGSI-INF-001	**Versión**	1.7
Estado	Borrador	**Clasificación**	Confidencial
Propietario	Dirección General — Atalaya GP SL	**Autor**	El consultor (externo)
Fecha de emisión	24/07/2026	**Fecha de aprobación**	Pendiente
Aprobado por	Pendiente conforme a DOC-002 §4	**Registro de aprobación**	Sin acta de aprobación de esta revisión. No acredita implantación ni firma contractual.

Historial de versiones

Versión	Fecha	Autor	Descripción del cambio
1.0	24/07/2026	El consultor	Emisión inicial. Informe de cierre del diseño del SGSI para la propiedad.
1.0	24/07/2026	Comité de Seguridad Convergente	Aprobación de la emisión inicial.
1.1	24/07/2026	El consultor	Corrección del recuento de riesgos sin cobertura convergente: siete corregidos, dos abiertos como deuda de diseño (HD-02).
1.1	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.1.
1.2	24/07/2026	El consultor	Corrección del recuento de escenarios en nivel Crítico en §3 (tres, no cinco).
1.2	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.2.
1.3	24/07/2026	El consultor	Corrección de §5 con los plazos reales del plan de tratamiento (SGSI-REG-002).
1.3	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.3.
1.4	24/07/2026	El consultor	Corrección de §1 (detección por conocimiento local, no matrícula) y de §6 (aceptación del riesgo residual). Ver decisiones.md §20 y §21.
1.4	24/07/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.4.
1.5	20/08/2026	El consultor	Recorte del historial de versiones a una línea por entrada, con referencia a decisiones.md donde procede. Sin cambios de fondo.
1.5	20/08/2026	Comité de Seguridad Convergente	Aprobación de la revisión 1.5.
1.6	20/09/2026	Autor del caso	Revisión de coherencia de septiembre. Deltas y verificación en docs/fase1-iso27001/correcciones_2026-09.md. Sin

Versión	Fecha	Autor	Descripción del cambio
			cambios en la fecha de corte.
1.7	27/09/2026	Autor del caso	Revisión por dominios aplicables y alcance de controles. Corte 24/07/2026 conservado. Aprobación pendiente. Deltas: revisión 2026-09-27.

Este informe se lee desde el punto 1. La tabla de arriba está porque las normas del propio sistema la exigen (SGSI-DOC-002 §2); no hace falta leerla.

1. Qué pasó

El invierno pasado, alguien encargó a un intermediario local reunir información sobre esta familia. El intermediario no llamó a la puerta ni forzó nada: se dejó ver donde se mueve el hijo mayor, y fue el hijo mayor quien buscó el contacto. Durante semanas le fue contando rutinas, viajes y detalles de cómo está protegida la finca. Después alguien vino a comprobar sobre el terreno lo que le habían contado.

No pasó nada. Y no pasó nada por suerte. Un miembro del servicio de seguridad reconoció un coche aparcado donde no debía, y semanas más tarde volvió a verlo en una foto que el hijo mayor había publicado. Ató los dos cabos él solo, de memoria.

Esa es la parte que hay que entender: la casa se salvó porque esa persona estaba de servicio ese día y conocía ese coche y a quien lo llevaba. No lo sacó de una matrícula ni de una lista: lo sabía. Si hubiera librado, o si hubiera sido otro, nadie habría atado nada. Ninguna cámara, ninguna alarma y ningún antivirus habrían cortado esto, porque la información salió por un lado y el peligro entró por el otro. Ese hueco entre los dos lados es lo que este trabajo viene a cerrar.

2. Qué se ha montado

Un sistema de gestión de seguridad de la información diseñado sobre ISO/IEC 27001, adaptado al escenario residencial ficticio. Sigue en implantación y no se presenta como certificado. En términos prácticos:

- Se han identificado y valorado 25 situaciones concretas que podrían hacer daño a esta familia, contadas como lo que son: secuencias de hechos encadenados, no listas de amenazas abstractas.
- Para cada una hay controles asignados: 64 en total, cada uno con un responsable designado, encuadrado en uno de los 16 planes de trabajo con su plazo, y con una periodicidad fijada para comprobar que sigue funcionando.
- Hay reglas escritas para lo que antes se hacía de memoria: verificación de órdenes de dinero, viajes, acceso de terceros a la casa, y qué se publica y cuándo.
- En cada riesgo se examinan el lado físico y el digital. Cuando ambos intervienen, ambos requieren cobertura; cuando uno no interviene, se justifica. No se añaden medidas para completar etiquetas. El programa comprueba esta regla con los datos del registro, pero no decide si el riesgo residual es aceptable.

La revisión del 27/09/2026 corrige la exigencia anterior de cubrir siempre ambos lados. Se retira un control sin relación con su cadena y se separan medidas organizativas, condicionadas y pendientes de justificar. La revisión deja visibles las carencias reales y no acredita que las medidas se hayan implantado.

3. Lo que más va a sorprender

Al principio la lista de riesgos estaba escrita pensando en un enemigo: alguien que ataca. Después se revisó con el jefe de seguridad, mirando lo que pasa un martes cualquiera. Y la lista cambió de forma.

Hoy, de los tres riesgos que encabezan la lista de esta casa, dos no tienen a nadie atacando en el origen. Uno de ellos, empatado con lo que pasó el invierno pasado, es sencillamente que la casa no se cierra bien: la alarma que no se conecta al salir, la ronda que se descuida en una conversación larga, la puerta de servicio que queda abierta. El otro es que los chicos meten en casa a quien les parece sin que nadie lo sepa antes.

No es una crítica al personal: es lo que pasa cuando algo lleva años haciéndose por costumbre y nadie apunta si se hizo. Un control contratado que no se ejecuta protege exactamente igual que uno que no existe, y esta casa tiene varios así.

4. Qué cambia para la familia

Lo mínimo posible, y por decisión expresa. Un sistema que obliga a vivir de otra manera no se cumple: se incumple a escondidas, que es peor. Lo que sí cambia:

- Redes sociales: no se prohíbe publicar. Se publica después de haber salido del sitio. La foto es la misma; lo que se le quita es el valor de decirle a alguien dónde estáis ahora mismo.
- Invitados en casa: aviso previo del nombre, y una zona social definida donde no se ve el sistema de seguridad. Nada de firmar papeles ni identificar a los amigos de los chicos en la puerta.
- Dinero: ninguna orden se ejecuta solo porque alguien la pida por teléfono, ni siquiera si esa voz es la suya. Hoy hay cientos de horas de su voz en internet y clonarla es cuestión de minutos. Está prevista la comunicación a los bancos por escrito.
- Viajes: la ficha del destino se hace antes de reservar, no después.

Todo lo que afecta a la familia se acuerda con la representante de la propiedad y se habla en persona, nunca por circular. Ese papel está formalizado en el sistema, con sus competencias y sus límites por escrito.

5. Lo que todavía no está hecho

Este informe presenta el diseño revisado y sus pendientes; no acredita la implantación. A día de hoy ningún control del plan está terminado y funcionando con registro de que se ejecuta. Es lo normal a estas alturas, pero conviene decirlo claro para que nadie se quede con la impresión de que ya está resuelto.

Hay 16 planes de trabajo diseñados. Las aprobaciones históricas pertenecen a la narración ficticia; los planes afectados por esta revisión necesitan nueva validación y aceptación por sus propietarios. Los plazos originales se conservan, sin simular que se han ejecutado. El cierre diario de la residencia, la coordinación de recogidas, la verificación de órdenes y la relación con terceros siguen siendo prioridades. La primera auditoría interna está planificada para el primer semestre de 2027.

El registro revisado contiene once hallazgos de diseño: tres cierres históricos y ocho abiertos. Incluyen justificación de controles, cobertura de dominios aplicables, seguimiento del proveedor y privacidad. Los vencimientos históricos de HD-02 y HD-03 están pendientes de decisión. La mejora documental no demuestra eficacia operativa.

6. Qué se le pide a usted

Cinco cosas, y ninguna es papeleo:

- Que mantenga lo que ya firmó: la declaración de una página. Es el documento que sostiene todo lo demás.
- Que la comunique usted en persona al personal y a la gente de su confianza. Aquí la autoridad que se reconoce es la suya, no la de un procedimiento.
- Que cumpla las reglas también usted. La primera vez que se salte una delante de alguien, el sistema se acaba.
- Que respalde la revisión del tratamiento de los riesgos pendientes. El propietario del riesgo aprueba el plan y acepta el residual; cuando sea Alto, se añade la ratificación del Comité prevista en la metodología. Las puntuaciones residuales conservadas son previsiones históricas, no resultados medidos; los planes afectados por esta revisión deben revalidarse.
- Que dedique una reunión al año a esto, en julio. Una. Con el resumen delante y la posibilidad de preguntar lo que quiera.

Documento de referencia completo: SGSI-REG-001/002 (lista de riesgos y planes) y SGSI-DOC-010 (cómo se revisa y se audita el sistema). Este informe es la entrada de la revisión anual con la propiedad prevista en SGSI-DOC-010 §3.